



# Release and Change Management — TASCO Growth Platform

---

TASCO Insurance × VETC Growth Platform — Operations

iorta TechNXT

Version 1.0 · 07 October 2026

# Contents

1. Two kinds of change
2. Versioning
3. Branching
4. CI/CD pipeline and gates
5. CAB process
6. Database migration policy
7. Feature flags via rules
8. Rule change procedure (maker-checker)
9. Release notes template
10. Freeze calendar

| Item       | Value                                                                                                                                                |
|------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| Owner      | Release Manager (iorta TechNXT during build and hypercare → TASCO IT)                                                                                |
| Approve rs | Change Advisory Board (CAB): TASCO IT Head (chair), TASCO PO, Compliance, Security, VETC IT (for changes affecting VETC interfaces), iorta Tech Lead |
| Related    | <a href="#">Test strategy</a> (CI gates) · <a href="#">Go-live plan</a> · <a href="#">Runbook</a>                                                    |

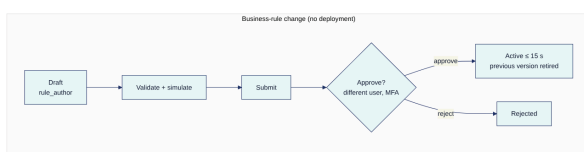
## 1. Two kinds of change

The platform separates **code** from **business rules**. They have different risk profiles and different paths to production.

|          | Code / configuration change                                                                                                                                                                                                   | Business-rule change                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| What     | <code>src/**</code> , <code>db/migrations/*.sql</code> , <code>config/security/rbac.json</code> (security config is code), <code>Dockerfile</code> , <code>deploy/**</code> , environment variables and secrets, dependencies | Any of the 21 rule kinds stored in the <code>rulesets</code> table: <code>scoring</code> , <code>nba</code> , <code>journeys</code> , <code>triggers</code> , <code>benefits</code> , <code>contact_policy</code> , <code>copy_guard</code> , <code>content.messages</code> , <code>content.voicebot</code> , <code>products</code> , <code>tariff.*</code> , <code>rating.*</code> , <code>commission</code> , <code>enrichment</code> , <code>abac</code> , <code>retention</code> , <code>costs</code> , <code>referral</code> , <code>service_levels</code> (quote TTL, claim acknowledgement SLA, evidence confidences) |
| Path     | Git PR → CI gates → release tag → CAB → deployment                                                                                                                                                                            | Rules studio: draft → validate → simulate → submit → <b>approve by a different person</b> (maker-checker) → active within ~15 s on all replicas                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Who      | Developers; release manager deploys                                                                                                                                                                                           | <code>rule_author</code> drafts; <code>rule_approver</code> or <code>compliance_officer</code> (MFA) approves                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Evidence | PR review, CI results, release notes                                                                                                                                                                                          | Audit trail ( <code>rules.draft_created</code> , <code>rules.submitted</code> , <code>rules.approved / rejected</code> ), checksum, simulation result, approval comment                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Rollback | Redeploy the previous image tag                                                                                                                                                                                               | <code>POST /api/rules/&lt;previous-id&gt;/rollback</code> → new draft → approval                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| CAB?     | Yes (standard, normal or emergency)                                                                                                                                                                                           | <b>No CAB for routine rule changes.</b> Maker-checker is the control. CAB is notified weekly of activations. <b>Exceptions needing CAB/Compliance pre-approval:</b> <code>contact_policy</code> , <code>copy_guard</code> , <code>abac</code> , <code>commission</code> , <code>tariff.*</code> , <code>retention</code> , and enabling anything with <code>legalStatus: pending_legal_review</code>                                                                                                                                                                                                                         |

`config/rules/*.json` in git holds only the **defaults** used to seed an empty database ( `npm run job -- rules` loads kinds that have no version yet). Editing those files **does not change production rules** once seeded.

Production rules change only through the rules studio. When a production rule change should also become the default for new environments, mirror it into git with a PR that references the rule version and checksum.



## 2. Versioning

- **Semantic versioning** of the application ( `package.json` `version` , exposed in `GET /api/meta` and the OpenAPI `info.version` ):
  - **MAJOR**: breaking change to a public contract (partner API `/api/partner/v1/*` , customer API used by the VETC app, event payloads consumed outside the platform). The partner API is additionally versioned in the path ( `/v1/` ), so a breaking partner change means `/v2/` alongside `/v1/` with a deprecation period of  $\geq 6$  months.
  - **MINOR**: backward-compatible features, new endpoints, new optional fields, new migrations (additive).
  - **PATCH**: bug fixes and security patches, with no contract change.
- **Images** are tagged `vX.Y.Z` and `sha-<gitsha>` . Deployments reference the immutable digest.
- **Rule sets** are versioned independently: `<kind>@<n>` with a SHA-256 checksum (first 16 hex). `GET /api/ops/status` lists the active version and checksum of each kind. The release notes record the rule versions validated with that release.
- **Database schema**: numbered migrations `NNN_description.sql` , recorded in `schema_migrations` .

## 3. Branching

Trunk-based development with short-lived branches.

| Branch                                           | Purpose                                                         | Rules                                                                                                                                                                                                                                                                    |
|--------------------------------------------------|-----------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>main</code>                                | Always releasable                                               | Protected; PR with $\geq 1$ approving review (2 for <code>src/application/identityService.js</code> , <code>accessPolicy.js</code> , <code>shared/crypto.js</code> , <code>config/security/*</code> , <code>db/migrations/*</code> ); all CI gates green; linear history |
| <code>feature/&lt;ticket&gt;-&lt;slug&gt;</code> | Work in progress                                                | Rebased on <code>main</code> ; lives $\leq 3$ days; incomplete features hidden behind rule-based flags (§7)                                                                                                                                                              |
| <code>release/X.Y</code>                         | Stabilisation when a release needs a freeze (e.g. go-live, Tết) | Cut from <code>main</code> ; fixes cherry-picked from <code>main</code>                                                                                                                                                                                                  |
| <code>hotfix/X.Y.Z</code>                        | Emergency fix on a released version                             | From the release tag; merged back to <code>main</code>                                                                                                                                                                                                                   |

Commits reference the ticket ID. PR descriptions include the test evidence and, for migrations, the rollback/compatibility note.

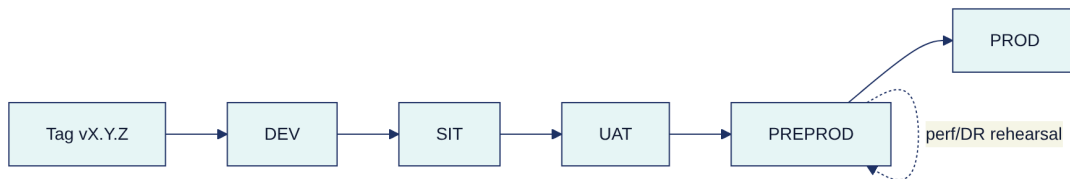
## 4. CI/CD pipeline and gates

`.github/workflows/ci.yml` runs on every PR and on tags:

| Stage            | Command / tool                                                | Gate                                                             |
|------------------|---------------------------------------------------------------|------------------------------------------------------------------|
| Install          | <code>npm ci</code> (lockfile enforced)                       | —                                                                |
| Lint             | <code>npm run lint</code>                                     | 0 errors                                                         |
| Tests + coverage | <code>npm run test:coverage</code> (unit + integration + API) | Lines $\geq 80$ % , functions $\geq 80$ % , branches $\geq 70$ % |
| Security tests   | <code>npm run test:security</code>                            | All pass                                                         |

| Stage                  | Command / tool                                                                            | Gate                                                                                                                                       |
|------------------------|-------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------|
| Postgres tests         | <code>npm run test:pg</code> with a Postgres service                                      | All pass                                                                                                                                   |
| SAST                   | CodeQL                                                                                    | No new high/critical                                                                                                                       |
| Dependencies           | <code>npm run audit</code>                                                                | No high/critical in production dependencies                                                                                                |
| Secrets                | gitleaks                                                                                  | 0 findings                                                                                                                                 |
| Container              | Docker build → Trivy image + config scan                                                  | No critical (PR); no critical/high (tag)                                                                                                   |
| SBOM                   | CycloneDX                                                                                 | Attached to the release                                                                                                                    |
| DAST                   | ZAP baseline against the ephemeral/SANDBOX deployment                                     | No high (tag)                                                                                                                              |
| Contract               | <code>npm run job -- openapi → diff</code> against <code>docs/api/openapi.json</code>     | A diff must be committed. A diff on <code>/api/partner/v1/*</code> needs the <code>partner-contract-change</code> label and partner notice |
| Migration immutability | Script: fail if any <code>db/migrations/*.sql</code> present on <code>main</code> changed | Hard fail                                                                                                                                  |
| Perf smoke (tag)       | <code>npm run test:perf</code> against the ephemeral deployment                           | p95 within 120 % of the baseline                                                                                                           |

Deployment (CD), per environment, promoted with the **same image digest**:



PROD deployment sequence:

1. CAB approval recorded.
2. Migration Job (`npm run migrate`, separate DB role with DDL rights) completes.
3. Rolling update (`maxUnavailable: 0`, `maxSurge: 25 %`). Readiness gates traffic; `SIGTERM` drains old pods ( $\leq 25$  s).
4. Smoke tests ([go-live plan §3.1](#)).
5. Watch dashboards D1–D3 for 30 min, then close the change.

Deployment windows: **Tue–Thu 21:00–23:00 ICT** (outside the 08:00–20:00 contact window and before the 08:30 journey run). No deployments on the day before public holidays, during Tết (1–14 Feb 2027) or during month-end renewal peaks unless emergency.

## 5. CAB process

| Change type                                          | Examples                                                                                                                                               | Approval                | Lead time |
|------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------|-----------|
| <b>Standard</b> (pre-approved, low risk, repeatable) | PATCH release passing all gates with no migration; scaling within HPA bounds; certificate renewal; SOP-04 partner key issue/revoke; SOP-03 offboarding | Release manager; logged | Same day  |

| Change type      | Examples                                                                                                                                 | Approval                                                                                                                 | Lead time         |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|-------------------|
| <b>Normal</b>    | MINOR/MAJOR release; any migration; config/secret change (SOP-01, SOP-02); RBAC changes; infrastructure changes; new partner integration | Weekly CAB (Wednesday 14:00 ICT)                                                                                         | ≥ 3 business days |
| <b>Emergency</b> | Sev 1/2 fix; security patch for an actively exploited vulnerability                                                                      | E-CAB: TASCO IT Head + PO (+ Compliance if customer-facing contact is affected), by phone/chat; ratified at the next CAB | Immediate         |

The change record contains: description, risk and impact, linked tickets, release notes, test evidence (CI run, SIT/UAT where applicable), migration plan and compatibility, deployment and rollback steps, verification steps, communication plan, and the window.

## 6. Database migration policy

- Never edit a migration that has been applied** to any shared environment, even if it is "only whitespace". The file name is the identity in `schema_migrations`, so an edit is silently skipped where already applied and diverges elsewhere. Add a new numbered file instead ( `002_...sql` ). CI enforces this (§4). The header of `db/migrations/001_init.sql` states the same rule.
- Forward-only, expand/contract.** Every migration must be compatible with the **previous** application version, so an application rollback (R3) never needs a schema rollback:
  - Expand*: add tables, nullable columns and indexes ( `CREATE INDEX CONCURRENTLY` in a dedicated migration for large tables. Note that `migrate()` wraps each file in a transaction, so `CONCURRENTLY` must instead go in a manual DBA step referenced by the change).
  - Migrate data*: in batches via a job, not inside the DDL migration.
  - Contract* (drop or rename): only in a later release, once no running version uses the old structure.
- Schema registry parity**: `src/adapters/persistence/schema.js` (collections, index columns, blind indexes) must match the SQL. A unit test checks parity ( `test/unit/platform.test.js` , "schema drift guard").
- Migrations are idempotent where possible ( `IF NOT EXISTS` ), reviewed by the DBA, timed on PERF data (6 M rows), and run by the **migration Job** before the rollout ( `MIGRATE_ON_START=false` in Kubernetes, KI-30).
- Destructive data changes (deletes, PII-touching updates) need a fresh PITR restore point noted in the change record and DPO consultation where personal data is affected.

## 7. Feature flags via rules

The platform has no separate feature-flag service. Exposure is controlled through rule sets, which are versioned, simulated, maker-checker approved and audited:

| Need                                  | Rule kind and field                                                                                                                                                                                                         | Example                                                                                    |
|---------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| Turn a product on/off, or per channel | <code>products.products[].status</code> , <code>.channels[]</code>                                                                                                                                                          | Hide <code>MOTOR_PD</code> from <code>partner_api</code> until the inspection flow is live |
| Bundles                               | <code>products.bundles[].status</code>                                                                                                                                                                                      | Activate a TNDS + PA bundle                                                                |
| Benefits to customers                 | <code>benefits.items[].legalStatus</code> (only <code>approved</code> reaches customers) and <code>available</code> ( <code>false</code> hides an approved item that is not yet operational, e.g. <code>auto_renew</code> ) | <code>loyalty_points</code> stays <code>pending_legal_review</code> until Legal approves   |

| Need                                 | Rule kind and field                                                                        | Example                                                                         |
|--------------------------------------|--------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------|
| Referral programme                   | <code>referral.enabled</code>                                                              | Disabled until legal approval                                                   |
| Journey targeting / regional rollout | <code>journeys.journeys[].audience</code> , <code>.steps[]</code> , <code>onlyTiers</code> | Pilot: restrict the audience to <code>region ∈ {Hà Nội, TP. Hồ Chí Minh}</code> |
| Event triggers                       | <code>triggers.triggers[]</code>                                                           | Enable <code>long_trip</code> at W2                                             |
| Contact intensity                    | <code>contact_policy.caps</code>                                                           | Emergency marketing stop: <code>maxMarketingContactsPerDay : 0</code>           |
| Voice script                         | <code>content.voicebot</code>                                                              | Prompt wording and intents                                                      |
| Access attributes                    | <code>abac.policies[]</code>                                                               | Regional restriction (CAB-reviewed)                                             |

Code-level features that are not ready are **not merged into main enabled**. They are either behind one of the rule switches above or not routed. `demoOnly` routes are disabled whenever `DEMO_MODE=false`.

## 8. Rule change procedure (maker-checker)

| Step                   | Who                                                                                | How                                                                                                                                                                        | Control                                                                                                                                                                                                                                                                           |
|------------------------|------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1. Draft               | <code>rule_author</code>                                                           | <code>POST /api/rules {kind, payload, description}</code>                                                                                                                  | Payload validated ( <code>validatePayload</code> : JSON Logic operators allow-listed, decision tables, kind-specific checks such as weights summing to 100 and $\text{commission} \leq \text{statutory cap}$ , plus the <b>copy guard</b> on content and benefits). Invalid → 400 |
| 2. Validate / simulate | Author                                                                             | <code>POST /api/rules/validate</code> ; <code>POST /api/rules/simulate {profileId, kind, payload}</code> for scoring, nba, journeys and benefits on the reference profiles | Evidence attached to the change note                                                                                                                                                                                                                                              |
| 3. Submit              | Author only                                                                        | <code>POST /api/rules/:id/submit</code>                                                                                                                                    | Only drafts, only by the author                                                                                                                                                                                                                                                   |
| 4. Review and approve  | <code>rule_approver / compliance_officer</code> , <b>not the author</b> , with MFA | <code>POST /api/rules/:id/approve {comment}</code> or <code>/reject</code>                                                                                                 | Self-approval → 403 (maker-checker)                                                                                                                                                                                                                                               |
| 5. Activate            | System                                                                             | The previous active version is retired; <code>rules.activated</code> event; caches invalidated; all replicas converge $\leq 15$ s                                          | Audit <code>rules.approved</code> with <code>supersedes</code>                                                                                                                                                                                                                    |
| 6. Verify              | Author + approver                                                                  | <code>GET /api/ops/status</code> shows the new version/checksum; monitor D4/D5 for 24 h                                                                                    | —                                                                                                                                                                                                                                                                                 |
| 7. Record              | Author                                                                             | Weekly rule-change log to CAB: kind, version, checksum, purpose, approver                                                                                                  | —                                                                                                                                                                                                                                                                                 |

Rule changes affecting customers are made **outside the contact window or before 08:30**, unless urgent, so a full journey run uses one consistent version.

## 9. Release notes template

```
# Release vX.Y.Z – <date>

## Summary
<one-paragraph business summary>

## Changes
| Ticket | Type (feature/fix/security/ops) | Description | Customer/partner impact |
|---|---|---|---|

## API and contract changes
- OpenAPI diff: <none | link>; partner API (/api/partner/v1) impact: <none | details +
notice date>
- Event payload changes: <none | details>

## Database migrations
| File | Purpose | Backward compatible with vX.Y.(Z-1)? | Est. duration on PROD volume |
|---|---|---|---|

## Configuration and secrets
- New/changed env vars: <...> (defaults, required in production?)
- Secret rotations: <...>

## Rule sets validated with this release
| Kind | Version | Checksum |
|---|---|---|

## Known issues
- KI-xx: <status / workaround>

## Test evidence
- CI run: <link> (lint, coverage %, security, pg, CodeQL, audit, gitleaks, Trivy, ZAP,
SBOM)
- SIT/UAT: <link>; perf smoke: p95 vs baseline <...>

## Deployment
- Window: <date/time ICT>; steps: migration Job → rollout → smoke tests
- Rollback: previous image <tag/digest>; rule rollback: <n/a | ids>

## Approvals
- CAB: <id/date>; Compliance (if customer-facing): <name/date>
```

## 10. Freeze calendar

| Period                                                  | Rule                                                                                           |
|---------------------------------------------------------|------------------------------------------------------------------------------------------------|
| Go-live release candidate (11–22 Jan 2027)              | Fixes only on <code>release/1.0</code>                                                         |
| <b>Tết Nguyên Đán (1–14 Feb 2027)</b>                   | No code deployments, no rule changes except emergency rollback (RB-10) or kill switch (SOP-07) |
| Each wave's first week (W1 from 29 Mar, W2 from 26 Apr) | Emergency changes only                                                                         |

| Period                           | Rule                                          |
|----------------------------------|-----------------------------------------------|
| Month-end (last 2 business days) | No normal changes affecting sales or journeys |